BINA NUSANTARA UNIVERSITY

School of Computer Science

Bachelor of Computer Science

SOFTWARE SECURITY AOL REPORT

COMP6549001 – Software Security

Threat Modelling, Attack Demonstration & Risk Mitigation Report

Company/Startup Name	Shopee E-Commerce
Academic Year / Semester	2025–2026 / Semester 4
Lecturer	Ayu Mauliana, S.Kom., M.Kom
Class	LC07

Group Members:

No.	Name	Student ID
1.	Andhika Permana Sagiyono	2802496691
2.	Darren Gavriel Suntara	2802396373
3.	Michael Ernst Jeremy Octama	2802487592
4.	Nathasa Bintang Kayesa	2802438754
5.	Sebastian Chang	2802498085

1. Executive Summary

1.1 Objek Kajian

Analisis ini mengkaji arsitektur keamanan pada platform Aplikasi Shopee yang merupakan startup E-Commerce dengan fokus evaluasi pada 5 fitur fundamental, yaitu: Payment (Pembayaran), Search Bar (Kolom Pencarian), Promo, Login/Register, dan sistem pengiriman Cash on Delivery (COD).

1.2 Ancaman Utama yang Diidentifikasi (Metodologi STRIDE)

Melalui pemetaan klasifikasi STRIDE, laporan ini mengidentifikasi beberapa ancaman kritis di setiap fitur yang berpotensi merugikan bisnis dan pengguna:

- **Tampering & Information Disclosure:** Injeksi basis data (SQL Injection) pada Search Bar, manipulasi logika kupon belanja, pembajakan data melalui Bypass Validasi Client-Side, serta manipulasi state management akun pengguna.
- **Repudiation (Penyangkalan):** Kerugian finansial akibat penolakan transaksi COD oleh konsumen yang memanfaatkan kelemahan sistem pencatatan log (Weak Logging) atau menggunakan perangkat bersama (Shared Device).
- **Spoofing & Elevation of Privilege:** Penyerangan berbasis Brute Force untuk mengambil alih akun pengguna/admin, SQL Injection pada form login/register, aksi Identity Spoofing lewat akun fiktif untuk kecurangan COD, serta phishing promosi palsu yang mengatasnamakan sales resmi.
- **Denial of Service (DoS/DDoS):** Kelumpuhan infrastruktur server akibat serangan Request Spamming pada momentum promo dan injeksi query pencarian yang sengaja dibuat kompleks/panjang (HTTP Flooding).

1.3 Serangan yang Didemonstrasikan

Serangan yang dipilih untuk didemonstrasikan adalah **Authentication Bypass via SQL Injection (SQLi)** pada fitur *Login*.

1.4 Strategi Mitigasi yang Diusulkan (Trade-Off Approach)

Mitigasi ini mengusulkan penanganan risiko berbasis prioritas menggunakan tiga pendekatan utama:

- **Address (Penyelesaian Langsung) :** Pembayaran & Akun Menerapkan prinsip Never Trust the Client melalui validasi ketat di sisi server (Server-Side Validation), Database Locking konkuren, penggunaan Idempotency Key, dan Parameterized Queries / ORM

modern dan Akses & Bukti Mengaktifkan batasan laju permintaan (Rate Limiting), Account Lockout, Output Encoding (untuk XSS), teknik pengikatan perangkat (Device Fingerprinting / Device Binding), serta implementasi audit log komprehensif yang anti-manipulasi.

- **Transfer (Pengalihan Risiko) :** Mengalihkan risiko serangan Identity Spoofing/Phishing pada fitur chat promo kepada pengguna lewat program edukasi keamanan siber secara berkala.
- **Accept (Menerima Risiko) :** Menerima risiko Request Spamming oleh bot pada fitur promo sebagai bentuk trade-off bisnis, dikarenakan biaya peningkatan kapasitas (hardware scaling) dinilai terlalu mahal dibandingkan dengan nilai risiko yang dihadapi.

2. Profil Perusahaan (Company Profile)

2.1 Informasi Umum Perusahaan

Nama Perusahaan / Startup	Shopee
Tahun Berdiri	Februari 2015
Bidang / Industri	E-Commerce Marketplace, Financial Technology (Fintech), Digital Financial Services
Produk / Layanan Utama	Shopee Marketplace, Shopee Mall, ShopeePay, SPayLater, SPinjam, Shopee Live, Shopee Ads, Cash on Delivery (COD), Shopee Guarantee
Jumlah Pengguna / Skala	± 400 juta active buyers dan 20 juta sellers secara global (2025); 53,22% pengguna internet Indonesia mengakses Shopee (APJII, 2025); market share e-commerce Indonesia mencapai 64,2% (Compas, 2024)
Website / Platform	shopee.co.id (Indonesia) · shopee.com (global) · Aplikasi mobile iOS & Android
Kontak / Narasumber	Desk Research (data publik, laporan resmi, observasi aplikasi)

2.2 Alur Bisnis (Business Flow)

Shopee beroperasi menggunakan model bisnis *hybrid marketplace* yang menggabungkan mekanisme C2C *(Consumer-to-Consumer)* untuk penjual individu dan B2C *(Business-to-Consumer)* untuk brand resmi melalui kanal Shopee Mall. Platform Shopee dirancang berpusat pada *mobile* dengan fokus sosial, menyediakan lingkungan belanja terintegrasi yang menggabungkan infrastruktur pembayaran, logistik, dan layanan penjual dalam satu ekosistem.

Secara keseluruhan, alur bisnis Shopee melibatkan lima aktor utama yang saling berinteraksi: Pembeli *(Buyer)*, Penjual *(Seller)*, Platform Shopee, *Payment Gateway*, dan Jasa Pengiriman. Berikut uraian alur masing-masing.

2.2.1 Alur Registrasi & Login Pengguna

Seluruh aktor, baik Pembeli maupun Penjual wajib memiliki akun terverifikasi sebelum dapat menggunakan layanan Shopee. Alur registrasi dan login adalah sebagai berikut:

Registrasi :

- Pengguna mengakses aplikasi Shopee (mobile/web) dan memilih opsi Daftar.
- Pengguna memasukkan nomor telepon atau alamat email.
- Sistem Shopee mengirimkan kode OTP (One-Time Password) ke nomor/email yang didaftarkan.
- Pengguna memasukkan kode OTP untuk memverifikasi kepemilikan akun.
- Pengguna melengkapi data profil (nama, kata sandi, tanggal lahir).
- Akun aktif dan pengguna diarahkan ke halaman utama.

Login :

- Pengguna memasukkan kredensial (email/nomor HP + kata sandi) atau menggunakan opsi Login dengan Google/Facebook.
- Sistem memverifikasi kredensial terhadap database pengguna.
- Jika valid, sistem membuat sesi terautentikasi dan mengirimkan token ke perangkat pengguna.
- Jika login gagal berulang kali, sistem menerapkan mekanisme penguncian sementara (temporary lockout).

2.2.2 Alur Transaksi Pembeli (Buyer Journey)

- **Eksplorasi Produk** : Pembeli melakukan pencarian melalui *search bar*, menelusuri kategori, mengakses Shopee Live, atau menerima rekomendasi berbasis AI dari sistem.

- **Detail Produk :** Pembeli membaca deskripsi, melihat ulasan, rating penjual, dan estimasi pengiriman.
- **Tambah ke Keranjang** : Produk dipilih dengan jumlah tertentu dan disimpan di keranjang belanja (*cart*).
- **Checkout** : Pembeli mengkonfirmasi keranjang, memilih alamat pengiriman, memilih jasa kurir, dan menerapkan voucher/koin Shopee.
- **Pembayaran** : Shopee menyediakan berbagai metode pembayaran, mulai dari transfer bank, kartu kredit/debit, *Cash on Delivery* (COD), ShopeePay, hingga SPayLater.
- **Dana Ditahan (Escrow)** : Setelah pembayaran dikonfirmasi, dana tidak langsung diberikan ke penjual, melainkan ditahan oleh sistem *Shopee Guarantee* sebagai jaminan perlindungan pembeli.
- **Notifikasi & Pemantauan** : Pembeli menerima notifikasi status pesanan dan dapat memantau pengiriman secara *real-time* melalui fitur *tracking*.
- **Konfirmasi Penerimaan** : Setelah barang diterima, pembeli mengklik "Pesanan Diterima". Dana dilepas ke penjual.
- **Ulasan & Rating** : Pembeli memberikan penilaian produk dan penjual. Ulasan tersimpan di database dan ditampilkan ke publik.

2.2.3 Alur Transaksi Penjual *(Seller Journey)*

- **Registrasi Toko** : Penjual mendaftar, melengkapi data toko, dan mengunggah dokumen identitas.
- **Manajemen Produk** : Penjual mengunggah produk (foto, deskripsi, harga, stok). Produk melalui proses moderasi Shopee sebelum tampil di platform.
- **Penerimaan Pesanan** : Saat ada pesanan masuk, penjual mendapat notifikasi dan wajib mengkonfirmasi dalam batas waktu yang ditentukan.
- **Pemrosesan & Pengiriman** : Penjual mengemas produk, menjadwalkan *pick-up* oleh kurir, dan memasukkan nomor resi ke sistem.
- **Pencairan Dana** : Dana dari Shopee Guarantee dicairkan ke rekening penjual setelah pembeli mengkonfirmasi penerimaan barang atau setelah batas waktu otomatis terlampaui.

2.2.4 Aktor Pendukung dalam Ekosistem Transaksi

- **Platform Shopee** : Berperan sebagai perantara netral: mengelola escrow dana, moderasi produk, penegakan kebijakan, dan pencatatan seluruh log transaksi.
- **Payment Gateway** : Menerima request pembayaran terenkripsi dari Shopee, memverifikasi ke bank/e-wallet, lalu mengembalikan respons konfirmasi. Dana tidak langsung ke penjual melainkan ke rekening escrow Shopee.

- **Jasa Pengiriman** : Menerima data paket dari penjual, melakukan pick-up, memperbarui status tracking secara berkala ke sistem Shopee, dan mengkonfirmasi pengiriman akhir.

2.2.5 Model Pendapatan *(Revenue Model)*

Shopee menggunakan model bisnis marketplace revenue-based. Setiap penjual dikenakan biaya komisi sebesar 2–5% dari setiap transaksi yang besarnya bergantung pada kategori produk. Selain itu, Shopee menawarkan berbagai opsi iklan seperti Shopee Ads dan Shopee Live yang menghasilkan pendapatan dari biaya pemasangan iklan. Sumber pendapatan tambahan berasal dari layanan keuangan digital: bunga dan biaya administrasi SPayLater serta SPinjam yang diawasi oleh OJK dan Bank Indonesia.

2.3 Arsitektur Sistem & Infrastruktur Teknologi

2.3.1 Lapisan Frontend (Client-Side)

Shopee menggunakan React.js sebagai library utama antarmuka pengguna. React.js memungkinkan pembuatan UI interaktif dengan arsitektur berbasis komponen dan fitur *Virtual DOM* yang mengoptimalkan perenderan serta meningkatkan performa aplikasi. Redux digunakan untuk manajemen *state* global, sementara Webpack bertugas sebagai *module bundler*. Untuk pengujian kode *frontend*, Shopee menggunakan Jest dan Enzyme.

2.3.2 Lapisan Backend (Server-Side)

Backend Shopee menggunakan beberapa bahasa pemrograman sesuai fungsinya: Python untuk machine learning dan analisis data, Java untuk layanan backend yang membutuhkan skalabilitas tinggi, dan PHP untuk keperluan web. Sistem menggunakan RabbitMQ untuk message queuing guna memastikan konsistensi data dan toleransi kesalahan antar layanan.

Shopee menerapkan arsitektur *microservices* yang bersifat modular, memungkinkan *scaling* cepat tanpa gangguan. Pendekatan agile ini memungkinkan peluncuran fitur secara berkala, pengujian A/B, dan penyelesaian masalah dengan cepat.

2.3.3 Manajemen Data & Database

Shopee menggunakan kombinasi beberapa sistem basis data: MySQL sebagai *relational database* utama untuk data terstruktur seperti profil pengguna, daftar produk, dan detail pesanan; Redis untuk *caching* dan manajemen sesi guna mengurangi latensi; dan MongoDB untuk data tidak terstruktur seperti log, metadata, dan konten yang dihasilkan pengguna. Untuk pemrosesan data *real-time*, Shopee memanfaatkan platform seperti Apache Kafka atau Apache Pulsar untuk mengalirkan *event* seperti pembaruan status pesanan dan pelacakan aktivitas pengguna.

2.3.4 Infrastruktur Cloud & Jaringan

Shopee menggunakan strategi hybrid cloud dengan memanfaatkan beberapa penyedia cloud: Alibaba Cloud untuk operasi di kawasan Asia, serta AWS atau GCP untuk Asia Tenggara. Layanan yang digunakan mencakup *cloud-native databases*, fungsi *serverless*, dan klaster *Kubernetes* terkelola. Untuk mempercepat pengiriman konten, Shopee menggunakan CDN (*Content Delivery Network*) seperti Cloudflare atau Akamai. Pemantauan performa dilakukan melalui Prometheus dan Grafana.

2.3.5 Ringkasan Tech Stack Shopee

Lapisan	Teknologi
Frontend	React.js, Redux, Webpack, Babel, Jest and Enzyme, Sass
Backend	Java, Python, PHP, RabbitMQ
Database	MySQL, Redis, MongoDB
Real-Time	Apache Kafka, Apache Spark
Cloud	AWS, GCP, Alibaba Cloud
CDN/Edge	Cloudflare / Akamai
Monitoring	Prometheus, Grafana
Mobile	iOS (Swift), Android (Kotlin)
Payment	ShopeePay, PCI-DSS Gateway

3. Metode Pengumpulan Data (Data Gathering)

3.1 Metode yang Digunakan

Mengingat Shopee adalah perusahaan teknologi berskala internasional yang tidak membuka akses wawancara kepada publik umum, kelompok kami menggunakan pendekatan multi-method desk research yang dikombinasikan dengan observasi teknis langsung. Seluruh aktivitas dilakukan secara legal dan tidak melibatkan akses tidak sah ke sistem Shopee yang sesungguhnya.

3.1.1 Studi Dokumen Publik (Primary Desk Research)

Meliputi laporan keuangan resmi Sea Limited yang diajukan ke SEC (*Securities and Exchange Commission*) Amerika Serikat, laporan tahunan (*Annual Report*) 2024 - 2025, serta survei industri dari APJII, SimilarWeb, dan Compas.co.id. Dokumen-dokumen ini merupakan sumber primer yang terverifikasi secara hukum.

3.1.2 Observasi Langsung Aplikasi

Pengujian fitur-fitur kritis Shopee menggunakan akun pengguna aktif: registrasi, login, pencarian produk, proses *checkout*, pilihan metode pembayaran (ShopeePay, COD, SPayLater), fitur promo/voucher, dan sistem *tracking* pengiriman. Observasi dilakukan pada versi aplikasi mobile iOS dan Android, serta versi *web browser*.

3.1.3 Reconnaissance Pasif *(OSINT (Open Source Intelligence))*

Pengumpulan informasi teknis secara legal melalui sumber terbuka seperti job posting Shopee/Sea Limited di LinkedIn (untuk mengidentifikasi *tech stack*), dokumentasi teknis di GitHub, laporan dari *engineering blog* Shopee, dan analisis dari platform seperti BuiltWith dan Wappalyzer.

3.2 Hasil Pengumpulan Data

3.2.1 Temuan dari Dokumen Publik Sea Limited

Berdasarkan laporan keuangan Sea Limited Full Year 2025, Shopee melayani sekitar 400 juta *active buyers* dan 20 juta *sellers* secara global, dengan GMV Shopee yang melampaui US$100 miliar dan profitabilitas EBITDA positif baik di Asia maupun Brasil.

Survei APJII 2025 mengonfirmasi dominasi Shopee di Indonesia dengan 53,22% pengguna internet Indonesia mengaksesnya — meningkat signifikan dari 41,65% tahun sebelumnya. Ini berarti 1 dari 2 pengguna internet Indonesia adalah pengguna aktif Shopee.

3.2.2 Temuan dari Observasi Langsung Aplikasi

Hasil observasi teknis terhadap aplikasi Shopee mengidentifikasi temuan-temuan berikut yang relevan dengan kajian keamanan:

Fitur yang Diobservasi	Temuan Teknis	Implikasi Keamanan

Registrasi & Login	Menggunakan OTP berbasis SMS/email; mendukung OAuth (Google/Facebook)	Rentan SIM Swapping, Credential Stuffing
Search Bar	Input bebas tanpa pembatasan karakter khusus di sisi klien	Potensi SQL Injection, XSS
Checkout & Payment	Multi-metode; validasi voucher di sisi klien terlihat	Potensi Client-Side Bypass pada logika diskon
COD	Tidak ada mekanisme OTP konfirmasi penerimaan	Rentan penyangkalan (Repudiation)
Halaman Error	Pesan error umum, tidak membocorkan detail teknis sistem	Relatif aman dari Information Disclosure
Session Timeout	Sesi aktif cukup lama tanpa aktivitas	Risiko Session Hijacking pada perangkat bersama

3.3 Identifikasi Aset Kritis

Berdasarkan data yang dikumpulkan, identifikasikan aset-aset kritis yang perlu dilindungi:

No	Aset Kritis	Teknologi Terkait
1	Database Akun & Kredensial Pengguna	MySQL, Redis (session)
2	Sistem Autentikasi (Login/Register/OTP)	Backend Java/PHP, Redis
3	Search Engine & Query Parser	Backend, MySQL
4	Payment Gateway & ShopeePay	PCI-DSS Gateway, API
5	Sistem Promo, Voucher & Koin Shopee	Backend, MySQL
6	Database Transaksi & Riwayat Pesanan	PesananMySQL, MongoDB
7	Sistem COD & Konfirmasi Penerimaan	Backend, Mobile App
8	API Endpoints (REST/GraphQL)	Microservices
9	Admin Panel & Dashboard Seller	Backend, Web
10	Infrastruktur Cloud & CDN	AWS/GCP/Alibaba, Cloudflare
11	Sistem Chat Penjual-Pembeli	Real-time messaging

12	Mobile Application (iOS & Android)	Swift/Kotlin

4. STRIDE Threat Modelling

Bagian ini menerapkan framework STRIDE untuk memodelkan ancaman yang ada pada ekosistem tech startup yang dipilih.

4.1 Prinsip Dasar Threat Modelling

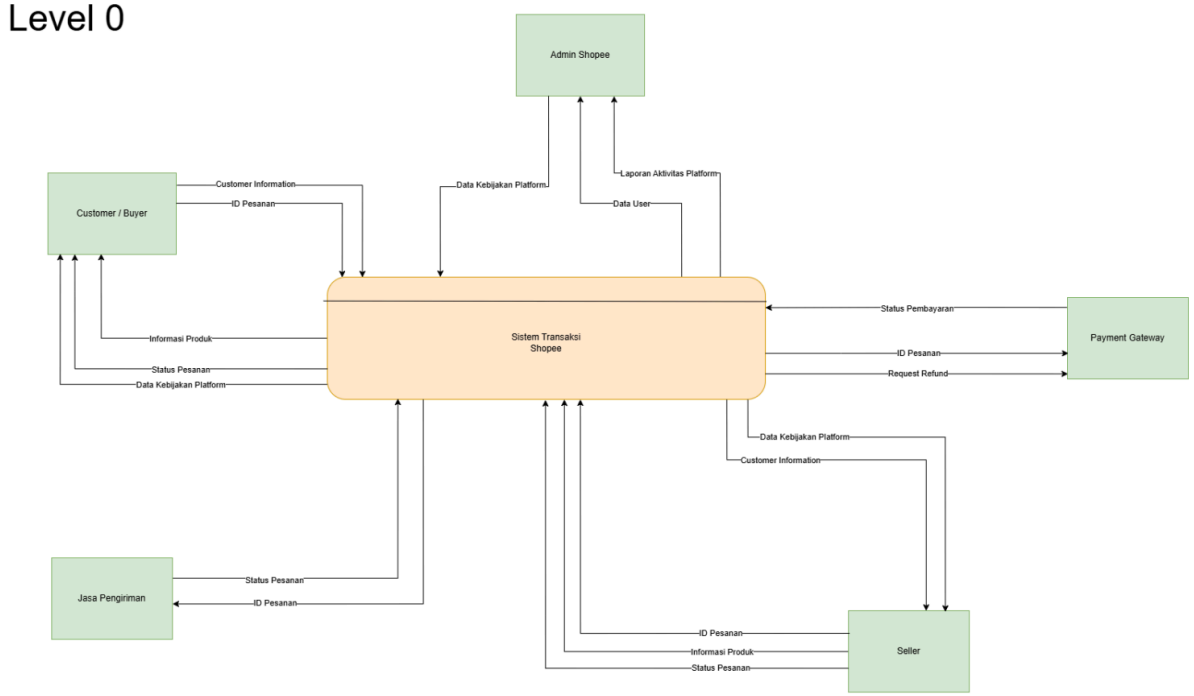
Threat modelling adalah proses terstruktur untuk mengidentifikasi, mengkuantifikasi, dan mengatasi ancaman keamanan pada suatu sistem. Framework STRIDE mengklasifikasikan ancaman ke dalam 6 kategori:

ID	Kategori	Definisi
S	**Spoofing**	Penyerang berpura-pura menjadi entitas yang sah, misalnya menggunakan kredensial curian atau memalsukan identitas.
T	**Tampering**	Modifikasi data yang tidak sah, baik saat transit maupun saat disimpan.
R	**Repudiation**	Penolakan atas tindakan yang telah dilakukan; tidak adanya audit trail yang memadai.
I	**Information Disclosure**	Pemaparan informasi kepada pihak yang tidak berwenang.
D	**Denial of Service**	Serangan yang bertujuan membuat layanan tidak tersedia bagi pengguna sah.
E	**Elevation of Privilege**	Mendapatkan hak akses yang lebih tinggi dari yang seharusnya dimiliki.

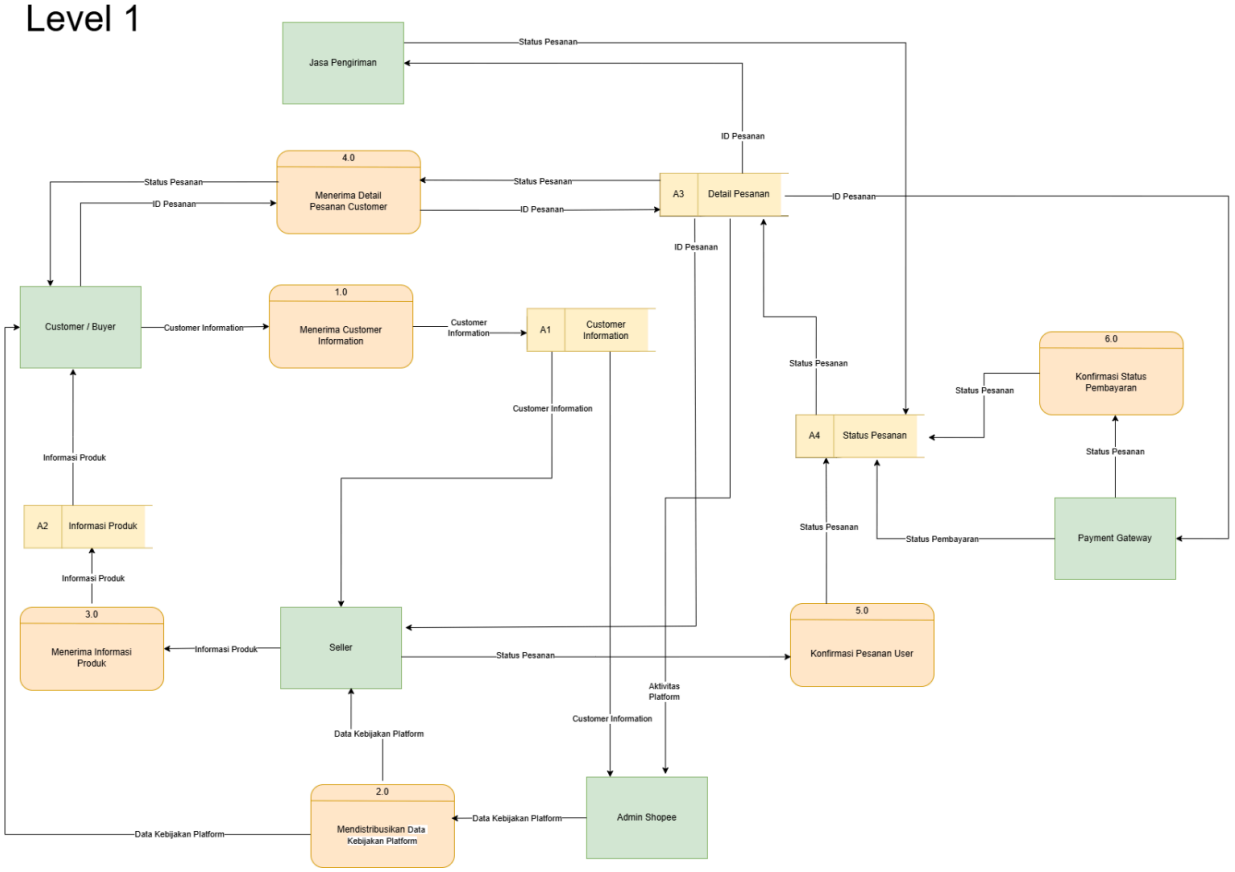
4.2 Data Flow Diagram (DFD)

Berikut adalah Data Flow Diagram level 0 dan level 1 dari aplikasi Shopee

Level 0



Level 1



4.3 Tabel STRIDE Threat Modelling

Berikut adalah hasil pemodelan ancaman menggunakan framework STRIDE pada studi kasus perusahaan:

ID	Kategori	Deskripsi Ancaman	Aset / Komponen Terdampak	Skenario Serangan	Tingkat Risiko	Status Mitigasi
S	**Spoofing**	Menyamar sebagai entitas lain	1. Authetication System 2. Databases & Credentials 3. Session	Attacker melakukan Credential Stuffing menggunakan daftar kredensial yang bocor dari layanan lain atau menggunakan *SQL Injection* untuk mengambil alih akun pengguna lain pada Sistem Autentikasi.	High	1.Mengimplementasikan MFA Seperti pop up push (saat login di laptop, shopee akan mengirimkan pop up setuju/tidak ke device lain yang memang sudah login). 2.Implementasi rate limiting 3.Menerapkan parameterized queries di bagian backend
T	**Tampering**	Memodifikasi data/kode secara tidak sah	1. Business Logic 2. Sistem Promo	Attacker dapat mengintercept dan memodifikasi parameter nilai Backend yang cenderung mengarah ke business logic seperti voucher saat transaksi Checkout & Payment di sisi klien karena validasi logika diskon yang lemah di sisi klien (Client-Side Bypass).	High	Memerlukan pemindahan seluruh logika perhitungan diskon dan validasi voucher sepenuhnya ke sisi server/backend).
R	**Repudiation**	Menyangkal tindakan yang telah dilakukan	1. Sistem COD & Konfirmasi Penerimaan	Pembeli nakal memanfaatkan celah keamanan pada sistem COD dengan	High	Mengimplementasikan fitur kode verifikasi OTP/QR Code unik yang harus diberikan pembeli

			2. Database Transaksi	menyangkal bahwa mereka telah menerima barang yang dikirim. Karena tidak adanya mekanisme verifikasi dua arah (seperti input OTP) saat kurir melakukan serah terima, sistem otomatis mengubah status pesanan menjadi "Selesai" hanya berdasarkan konfirmasi dari kurir sehingga catatan status pada **Database Transaksi & history Pesanan** kehilangan aspek *non-repudiation* dan integritasnya (karena hanya sepihak). data di dalam database tersebut menjadi lemah dan tidak cukup kuat untuk dijadikan bukti autentik, untuk membuktikan secara valid di sistem apakah pembeli atau kurir yang melakukan kebohongan.		kepada kurir saat konfirmasi penerimaan barang) sehingga konfirmasi menjadi tidak sepihak lagi melainkan 2 pihak yaitu kurir dan pembeli sama sama melakukan konfirmasi pesanan selesai
I	**Information Disclosure**	Membocorkan informasi sensitif	1. Search Engine & Query Parser 2. API Endpoints (REST/GraphQL)	Attacker melakukan input query/payload berbahaya pada *Search Bar* yang tidak memiliki input validation untuk melakukan teknik *SQL Injection* yang akhirnya berujung bisa melihat struktur database serta isi nya.	High	1. langkah utama yang harus dilakukan adalah menerapkan parameterized queries di bagian backend sehingga apa pun yang diketik oleh user akan dibaca sebagai teks biasa untuk mencari produk, bukan sebagai seuatu perintah komputer yang bisa merusak atau mengintip database.

						2. Membatasi jenis karakter yang boleh diketik (misalnya hanya huruf dan angka), serta membatasi hak akses akun database agar tidak bisa menghapus data sembarangan jika terjadi pembobolan. 3. Terakhir, perusahaan bisa memasang sistem keamanan tambahan seperti *Web Application Firewall* (WAF) untuk otomatis menyaring dan memblokir ketikan yang mencurigakan sebelum sempat masuk ke dalam sistem utama aplikasi.
D	**Denial of Service**	Mengganggu ketersediaan layanan	1. Infrastruktur cloud 2. Api endpoint	Attacker mengirimkan request pada kolom pencarian secara terus menerus dan sangat banyak yang bebas diketik tanpa batasan yang akan diteruskan ke **API Endpoints** Karena server dipaksa untuk memproses jutaan request palsu tersebut dalam waktu bersamaan, server menjadii kelelahan, kehabisan memori, dan tidak sanggup lagi menampung data. Hal ini membuat Infrastruktur Cloud (gerbang utama aplikasi) menjadi macet	High	1. Mengimplmentasikan Input Validation. Sistem harus membatasi jumlah huruf yang boleh diketik di kolom pencarian (misalnya maksimal hanya 100 karakter) dan melarang penggunaan simbol aneh. 2. Mengimplementasikan Rate Limiting. Menurut saya sebenarnya rate limiting ini merupakan kunci utama untuk memitigasi DoS/DDoS. Sistem akan membatasi berapa kali user boleh menekan tombol cari dalam satu menit (misalnya maksimal 10 kali pencarian per menit). Sehingga tidak mungkin

				total dan *down*. Akibatnya, pembeli atau penjual asli sama sekali tidak bisa membuka atau menggunakan aplikasi Shopee karena sistemnya down		ada spam request yang masuk ke sistem. 3. Memasang Satpam Digital (Web Application Firewall / WAF) Di level Infrastruktur Cloud. Tugasnya adalah menyaring semua lalu lintas yang masuk ke aplikasi. WAF ini bisa membedakan mana ketikan jari manusia asli dan mana serangan komputer dari botnet. Jika terdeteksi sebagai robot, aksesnya langsung diputus
E	**Elevation of Privilege**	Mendapatkan akses yang tidak sah	1. Session (Redis) 2. Admin Panel & Dashboard Seller	Attacker menginput script/payload berbahaya yang tersembunyi ke dalam sistem web misalnya melalui kolom input yang biasanya seperti forum (contoh di kasus shopee ini di bagian rating & ulasan) yang tidak aman dan tidak ada validasi nya. Ketika seorang Admin atau Penjual mengklik payload tersebut, *script* itu akan otomatis berjalan di browser mereka tanpa disadari. Script tersebut langsung bekerja mengintip dan mencuri Session Token milik Admin yang sedang aktif. Kode token yang dicuri ini kemudian dikirimkan secara	High	1. Untuk memitigasi ancaman ini, langkah utama yang harus dilakukan adalah mengaktifkan fitur HttpOnly pada cookie token sesi agar tersimpan di tempat yang aman dan sama sekali tidak bisa diintip atau dicuri oleh JavaScript hasil serangan XSS. 2. menerapkan Input Sanitization untuk menyaring setiap karakter aneh yang diketik pengguna agar tidak bisa berjalan sebagai kode program. Terakhir, 3. pemasangan Content Security Policy (CSP) di sisi browser untuk mendeteksi sekaligus memblokir eksekusi script asing yang mencoba

				otomatis ke server milik penyerang. Setelah mendapatkan token tersebut, penyerang memasukkannya ke dalam browser miliknya sendiri untuk melakukan Session Hijacking. Karena sistem mengenali token tersebut sebagai milik Admin yang sah, penyerang berhasil masuk ke dalam Admin Panel & Dashboard Seller tanpa perlu memasukkan username atau password. Hak akses penyerang yang awalnya hanya pengguna biasa kini langsung meningkat menjadi setingkat Admin, memberi mereka akses sebagai admin atau seller		berjalan di luar kode resmi aplikasi.

5. Demonstrasi Serangan (Attack Demonstration)

5.1 Lingkup & Persiapan

5.1.1 Jenis Serangan yang Dipilih

Serangan yang dipilih untuk didemonstrasikan adalah **Authentication Bypass via SQL Injection (SQLi)** pada fitur *Login*.

Berdasarkan pemodelan STRIDE, serangan ini mewakili dua ancaman utama sekaligus: **Spoofing** dan **Elevation of Privilege**. Serangan ini dipilih karena fitur autentikasi adalah gerbang keamanan paling krusial dalam aplikasi e-commerce. Jika fitur ini dapat ditembus, seluruh alur bisnis akan terdampak.

5.1.2 Lingkungan Pengujian

Target Sistem / Aplikasi	OWASP Juice Shop
Lingkungan	Lab
Tools yang Digunakan	Burp Suite, Web Browser
Tanggal Pelaksanaan	3 Juni 2026

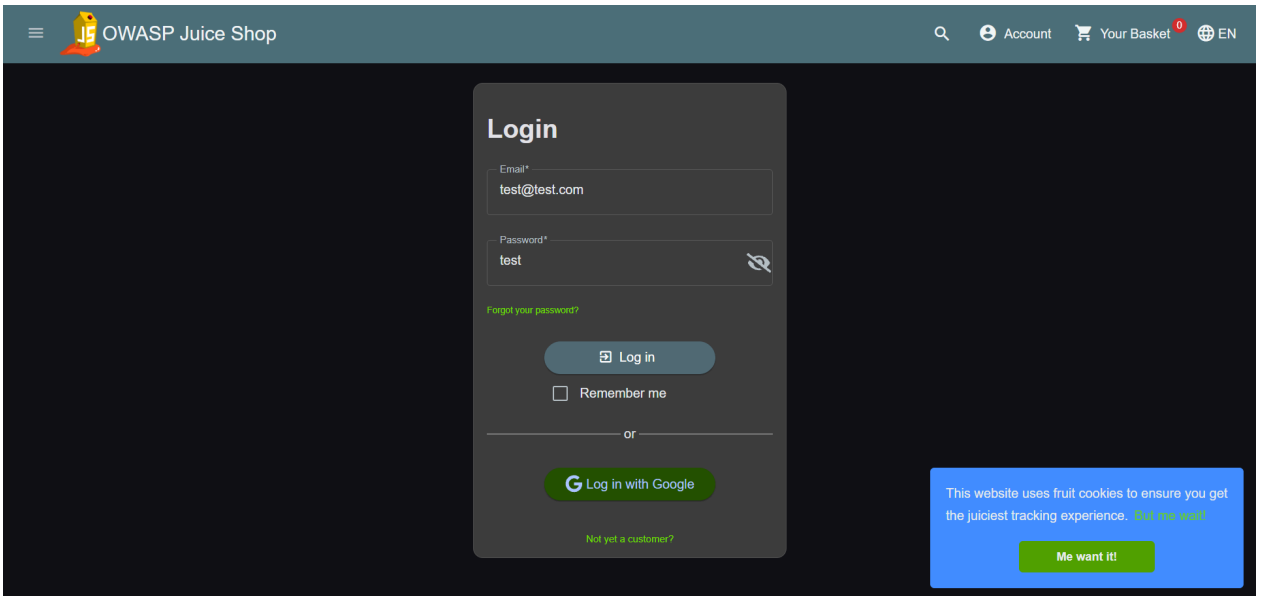
5.2 Langkah-Langkah Serangan (Step-by-Step)

Dokumentasikan setiap langkah serangan secara berurutan. Sertakan screenshot atau output dari setiap langkah.

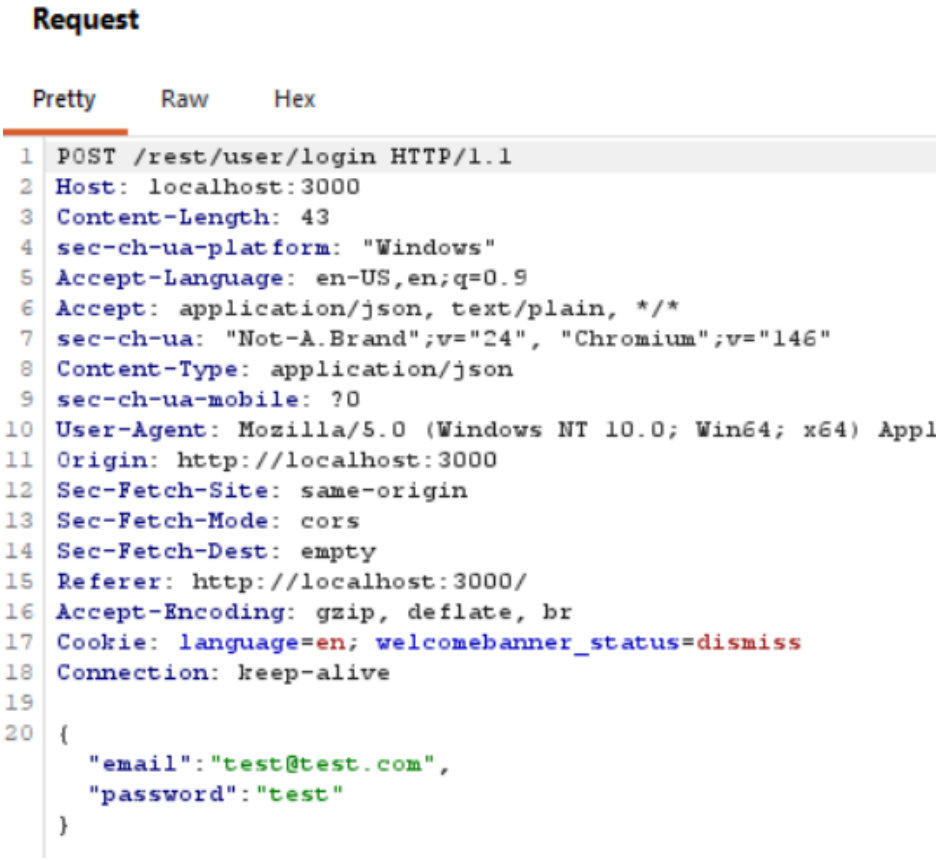
Step 1: Reconnaissance / Information Gathering

Langkah pertama adalah memahami bagaimana aplikasi menangani proses autentikasi dari *frontend* ke *backend*. Pengujian dilakukan dengan memasukkan email dan password standar (`test@test.com` dan `test`) pada login untuk menangkap struktur datanya.

- Tampilan Login



- Hasil HTTP Request dari Burp Suite

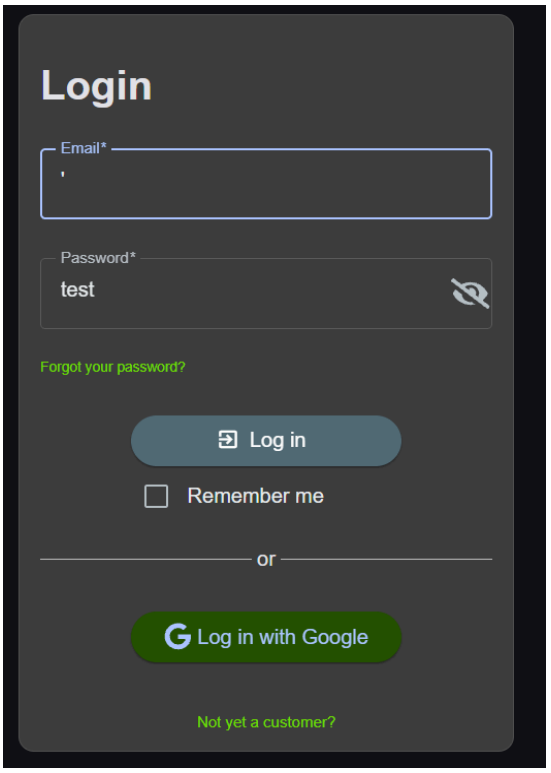


Analisis: Berdasarkan tangkapan *traffic* menggunakan Burp Suite, diketahui bahwa aplikasi mengirimkan data kredensial menggunakan metode `POST` ke *endpoint* `/rest/user/login`. Data dikirimkan dalam format JSON di bagian *body* permintaan, dengan struktur: `{"email":"test@test.com", "password":"test"}`.

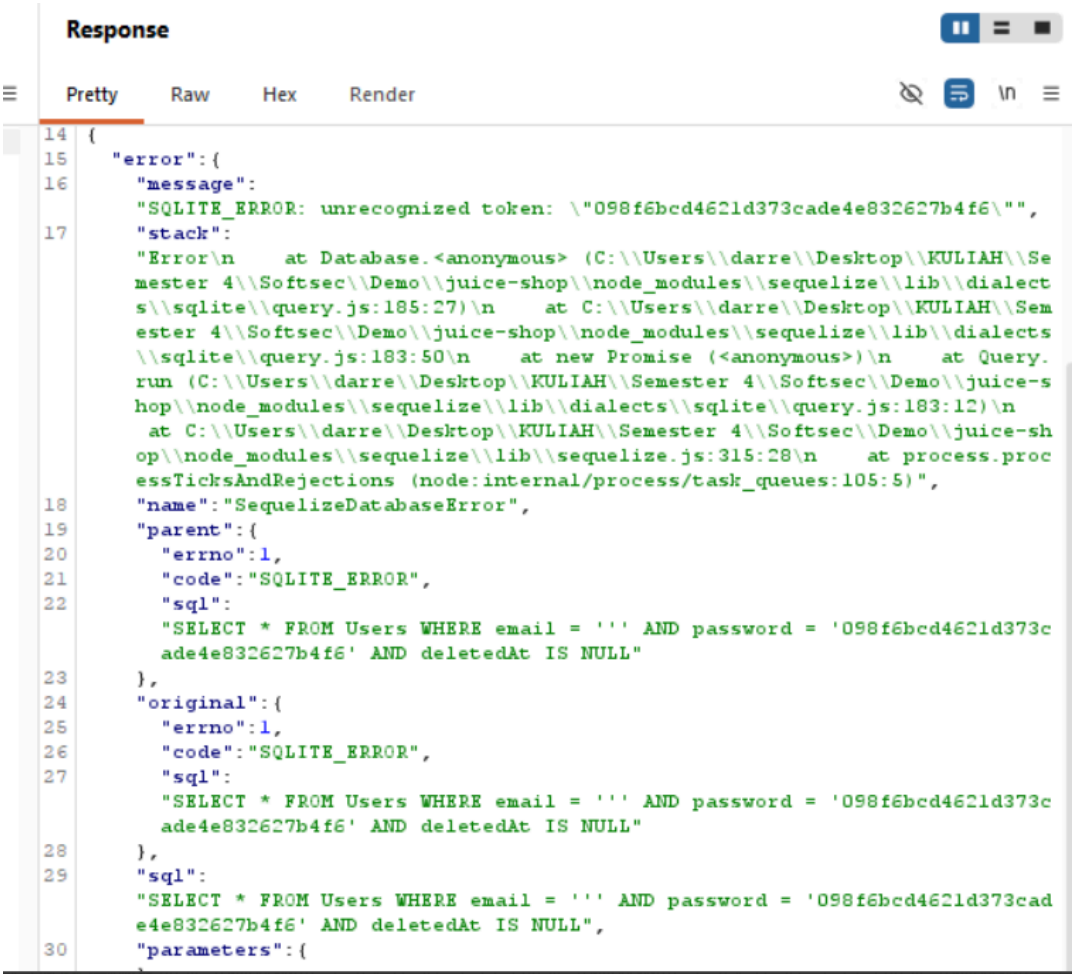
Step 2: Vulnerability Identification

Tahap ini bertujuan untuk mengidentifikasi apakah parameter `email` divalidasi dengan aman oleh *backend* atau rentan terhadap injeksi. Pengujian dilakukan dengan memasukkan karakter khusus SQL (') ke dalam parameter email.

- Input (') ke email



- Respon Error dari Server

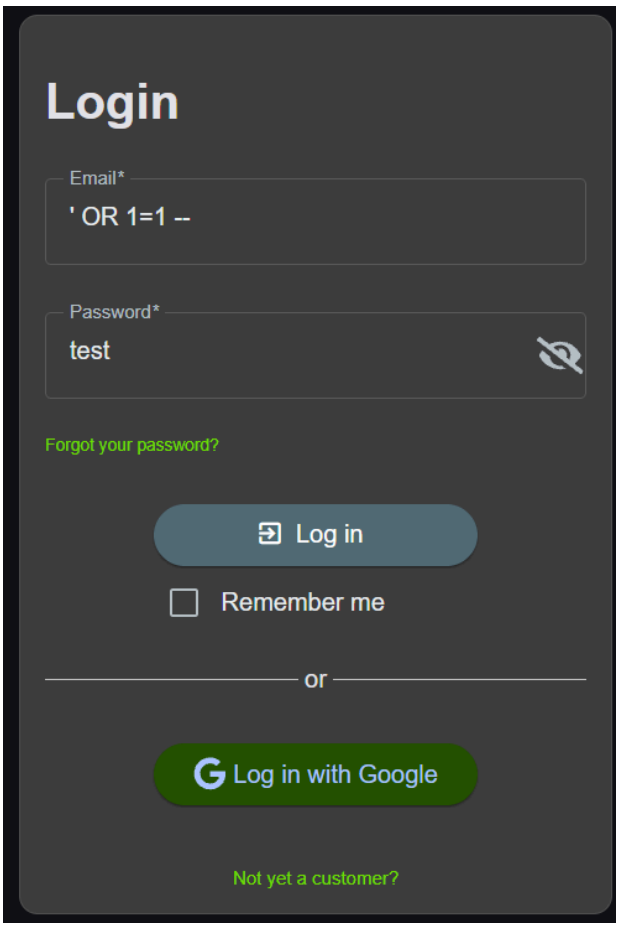


Analisis: Saat *payload* dikirimkan, server merespons dengan HTTP *Status Code* `500 Internal Server Error`. Di dalam balasan tersebut, server membocorkan pesan *error database* secara eksplisit: `SQLITE_ERROR: unrecognized token`. Kebocoran ini mengkonfirmasi dua hal: pertama, *database* yang digunakan adalah SQLite; kedua, aplikasi rentan terhadap SQL Injection karena karakter input langsung digabungkan ke dalam query SQL.

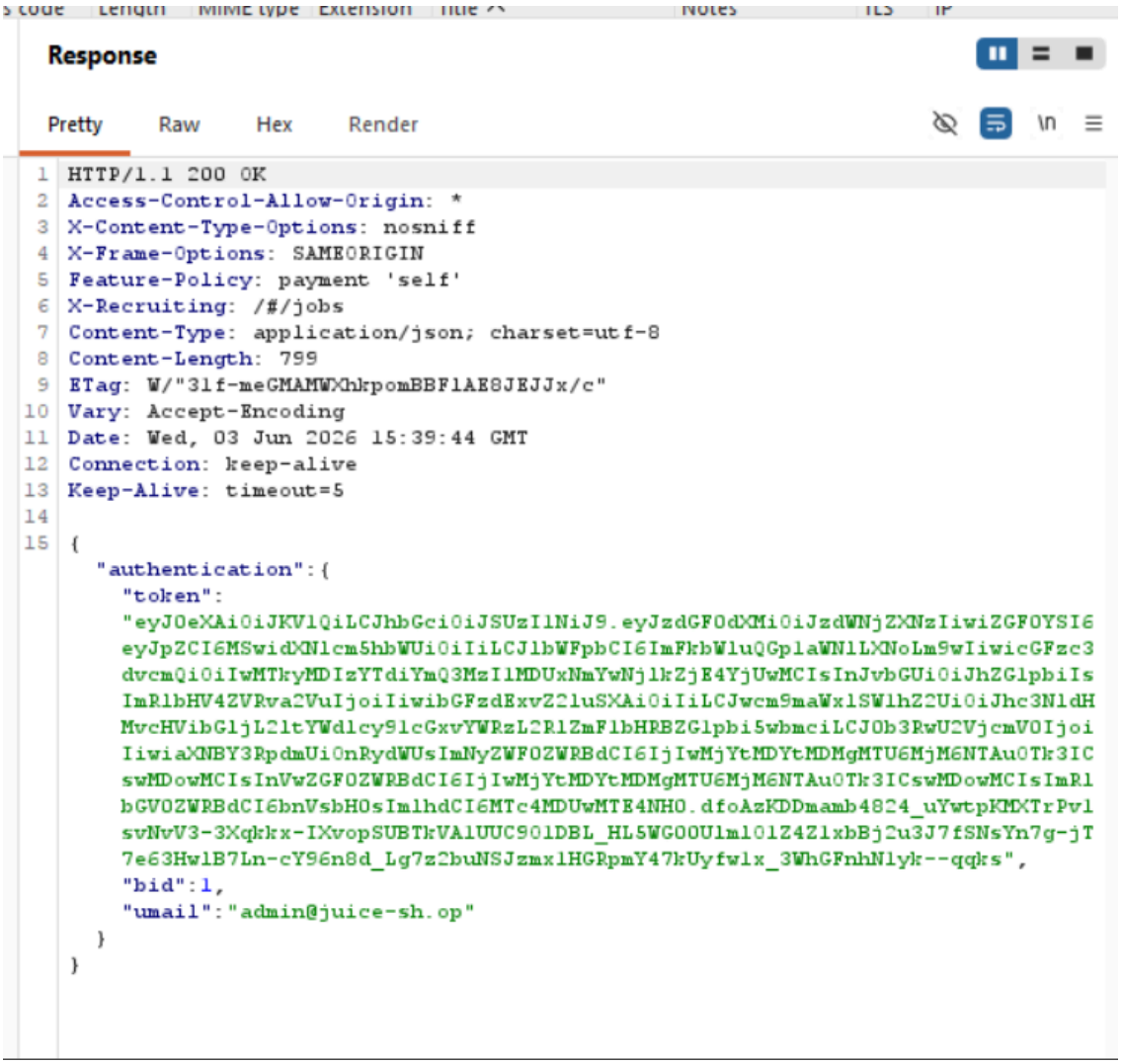
Step 3: Exploitation

Setelah kerentanan terkonfirmasi, eksploitasi dilakukan untuk memanipulasi logika autentikasi *database* agar sistem memberikan akses tanpa memvalidasi *password*. *Payload* injeksi Boolean-based digunakan pada kolom email.

- Memasukkan Payload SQL-Injection


Login
Email*
' OR 1=1 --
Password*
test
Forgot your password?
Log in
Remember me
or
Log in with Google
Not yet a customer?

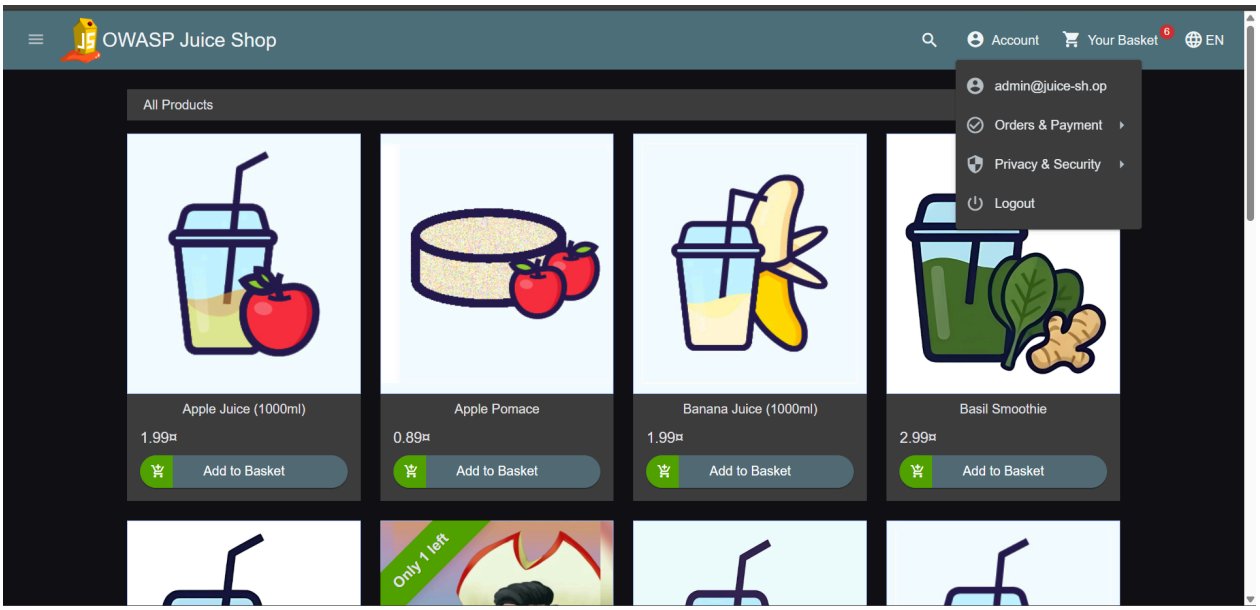
- Respon Sukses



Analisis: Penyerang memasukkan *payload* `'OR 1=1 --`. Logika ini mengubah query *backend* menjadi `SELECT * FROM Users WHERE email = '' OR 1=1 --' AND password = '...'`. Tanda `--` menghilangkan pengecekan password, dan `OR 1=1` menciptakan kondisi yang selalu benar. Seperti yang terlihat pada Burp Suite, server merespons dengan HTTP `200 OK` dan mengembalikan objek JSON berisi *Authentication Token* yang sah beserta data pengguna `"umail": "admin@juice-sh.op"`. Autentikasi berhasil dilewati.

Step 4: Post-Exploitation / Demonstration of Impact

- Tampilan Dashboard



Analisis: Serangan ini berdampak sangat fatal. Penyerang tidak hanya berhasil masuk ke dalam sistem (*Spoofing*), tetapi sistem secara otomatis mengautentikasi penyerang sebagai *user* pertama di *database*, yang merupakan akun Administrator (`admin@juice-sh.op`). Hal ini mendemonstrasikan *Elevation of Privilege* di mana penyerang kini memiliki kontrol penuh terhadap aplikasi, berpotensi mengakses data pribadi pelanggan lain, memodifikasi harga produk, atau merusak integritas sistem secara keseluruhan.

5.3 Analisis Dampak Serangan

5.3.1 Dampak Teknis

Dampak teknis dari serangan ini bersifat kritikal karena mengakibatkan kompromi penuh terhadap pilar keamanan *Confidentiality* dan *Integrity* .

- **Akses yang Diperoleh:** Penyerang berhasil membajak akun dengan hak akses tertinggi (Administrator / `admin@juice-sh.op`) tanpa perlu memecahkan atau menebak *password* sama sekali.
- **Data yang Terekspos:** Dengan akses tingkat *admin*, penyerang dapat mengekstrak seluruh data pengguna di dalam *database*, termasuk alamat email, *hash password*, alamat fisik pelanggan, dan riwayat pesanan (berpotensi memicu kerentanan *Information Disclosure* lebih lanjut).

- **Integritas Sistem:** Penyerang dapat memanipulasi *database* secara langsung dari antarmuka aplikasi, seperti mengubah harga produk menjadi nol, menghapus ulasan pelanggan, atau mendeaktivasi akun pengguna sah.

5.3.2 Dampak Bisnis

Bagi perusahaan startup e-commerce, eksploitasi celah ini akan memicu efek domino yang menghancurkan kelangsungan bisnis:

- **Kerugian Finansial:** Penyerang yang memiliki akses admin dapat memanipulasi alur pembayaran, membuat pesanan fiktif, mencairkan *voucher* tanpa batas, atau merusak harga katalog.
- **Pelanggaran Kepatuhan Regulasi:** Kebocoran data pribadi pelanggan secara massal akan melanggar Undang-Undang Pelindungan Data Pribadi (UU PDP) di Indonesia, yang dapat berujung pada denda administratif yang masif dari regulator.
- **Kehancuran Reputasi:** Hilangnya kepercayaan pelanggan dan mitra bisnis (seperti pihak logistik dan *payment gateway*) akibat inkompetensi perusahaan dalam menjaga data sensitif. Hal ini bisa menyebabkan penurunan *user retention* secara drastis.

5.3.3 Root Cause Analysis

Serangan ini dapat terjadi karena adanya kelemahan fundamental pada lapisan *backend* aplikasi:

1. **Kegagalan Validasi & Sanitasi Input:** Aplikasi gagal memvalidasi input dari *user interface* (form email) secara ketat. Karakter khusus SQL seperti tanda kutip tunggal (`'`) dan *double-dash* (`--`) diterima mentah-mentah oleh *server*.
2. **Penggunaan Dynamic SQL (String Concatenation):** Kelemahan paling fatal adalah cara *backend* menyusun kueri *database*. Aplikasi menggabungkan input pengguna langsung ke dalam string SQL (contoh: `SELECT * FROM Users WHERE email = '` + **input_user** + `'`). Hal ini menyebabkan *database* tidak bisa membedakan mana yang merupakan data *string* biasa dan mana yang merupakan perintah SQL yang harus dieksekusi.
3. **Insecure Error Handling:** *Server* dikonfigurasi secara tidak aman sehingga mengembalikan log *error database* secara eksplisit (seperti *SQLITE_ERROR*) ke *frontend*. Ini memberikan petunjuk berharga bagi penyerang (*Information Gathering*) mengenai jenis *database* dan struktur kueri yang digunakan.

6. Strategi Mitigasi & Remediasi Risiko

Bagian ini menyajikan rekomendasi mitigasi dan remediasi risiko yang komprehensif, spesifik, dan dapat diimplementasikan untuk setiap komponen STRIDE pada perusahaan yang dikaji.

6.1 Kerangka Mitigasi

Strategi mitigasi dirancang berdasarkan prinsip Defense-in-Depth dan disesuaikan dengan konteks bisnis serta teknologi perusahaan. Setiap rekomendasi mempertimbangkan: feasibilitas teknis, biaya implementasi, dan prioritas risiko.

6.2 Mitigasi per Komponen STRIDE

6.2.1 Spoofing

Ancaman Spoofing pada Shopee termanifestasi dalam dua skenario utama: (1) serangan Brute Force / Credential Stuffing pada fitur Login yang memungkinkan penyerang mengambil alih akun pengguna lain, dan (2) Identity Spoofing melalui akun palsu pada fitur promo yang bertujuan untuk menipu pengguna. Kedua ancaman ini dikategorikan pada tingkat risiko High dan Critical pada Excel Trade-Off Kelompok 3.

Rekomendasi	Detail Implementasi	Prioritas	Status
Multi-Factor Authentication (MFA)	Implementasikan MFA menggunakan Push Notification berbasis aplikasi mobile. Ketika pengguna login dari perangkat atau lokasi baru, sistem akan mengirimkan notifikasi konfirmasi ke perangkat terdaftar. Secara teknis, integrasikan library autentikasi seperti TOTP (RFC 6238) di backend Java/PHP Shopee. Tambahkan kolom 'trusted_devices' dan 'mfa_secret' pada tabel Users di MySQL. Untuk login berbasis OAuth (Google/Facebook) yang sudah ada, tambahkan lapisan verifikasi perangkat tambahan. MFA ini efektif menangkal Credential Stuffing karena meskipun kredensial bocor dari layanan lain, penyerang tetap	**High**	**Planned**

	tidak bisa masuk tanpa akses ke perangkat fisik pengguna.		
Rate Limiting & Account Lockout	Terapkan pembatasan percobaan login menggunakan mekanisme dua lapis: (a) Rate Limiting berbasis IP melalui Redis — maksimal 10 percobaan per menit per IP, setelah itu IP diblokir sementara selama 15 menit. (b) Account Lockout — akun dikunci sementara selama 30 menit setelah 5 percobaan gagal berurutan, dan pengguna dikirimkan notifikasi email/SMS. Implementasi menggunakan Redis sebagai token bucket counter karena sudah tersedia di infrastruktur Shopee. Tambahkan CAPTCHA (Google reCAPTCHA v3 yang bersifat invisible) setelah percobaan ke-3 untuk membedakan manusia dan bot tanpa mengganggu pengalaman pengguna.	**High**	**Planned**
Verifikasi Indentitas Akun Baru (KYC RIngan)	Untuk mencegah pembuatan akun palsu (Use Fake Account pada COD), terapkan KYC ringan berupa: wajib verifikasi nomor telepon aktif via OTP SMS saat registrasi, verifikasi email, dan untuk transaksi COD dengan nilai di atas threshold tertentu (misalnya Rp500.000), tambahkan verifikasi foto selfie menggunakan layanan AI seperti AWS Rekognition atau integrasi e-KTP digital (via Dukcapil API jika tersedia). Device Fingerprinting menggunakan library seperti FingerprintJS Pro dapat ditambahkan untuk mendeteksi pembuatan akun massal dari satu perangkat.	**Medium**	**Planned**

Analisis : Strategi mitigasi Spoofing diprioritaskan pada MFA dan Rate Limiting karena keduanya memiliki rasio cost-benefit yang sangat baik — biaya implementasi relatif rendah menggunakan infrastruktur Redis yang sudah ada, namun secara dramatis meningkatkan kesulitan bagi penyerang. KYC ringan ditempatkan sebagai Medium priority karena melibatkan integrasi pihak ketiga yang lebih kompleks dan berisiko menambah friction pada pengalaman pendaftaran pengguna baru.

6.2.2 Tampering

Ancaman Tampering pada Shopee meliputi: manipulasi status kupon (CAPEC-94), eksploitasi Race Condition pada transaksi (CAPEC-26), dan Bypass Validasi Client-Side pada proses checkout dan payment (CAPEC-153/207). Ketiga ancaman ini dikategorikan Critical pada Excel Trade-Off dan memerlukan penanganan teknis yang fundamental pada lapisan backend.

Rekomendasi	Detail Implementasi	Prioritas	Status
Server-Side Validation & Never Trust The Client	Prinsip 'Never Trust the Client' harus diterapkan secara menyeluruh: semua logika bisnis kritis (perhitungan harga, validasi kupon, penerapan diskon) wajib dieksekusi dan diverifikasi di sisi server/backend. Klien (browser/aplikasi mobile) hanya menampilkan hasil — tidak boleh mengirimkan nilai harga atau diskon yang telah dihitung. Implementasi teknis: backend Java/PHP harus selalu mengambil harga produk langsung dari database MySQL, bukan dari parameter yang dikirimkan client. Semua request checkout divalidasi ulang di server sebelum diproses ke payment gateway. Gunakan ORM (Hibernate/Sequelize) sebagai abstraksi database untuk mencegah manipulasi query langsung.	**High**	**Planned**
Database Locking & Idempotency Key	Untuk mengatasi Race Condition pada transaksi (CAPEC-26): Implementasikan Pessimistic Locking menggunakan SQL 'SELECT ... FOR UPDATE' di MySQL untuk memastikan satu baris data transaksi hanya diproses oleh satu thread pada satu waktu. Tambahkan mekanisme Idempotency Key — setiap request transaksi harus menyertakan UUID unik yang dihasilkan client; server menyimpan key ini di Redis dengan TTL tertentu dan menolak request duplikat dengan key yang sama. Untuk kupon, tambahkan mekanisme Soft Locking dengan time-to-live (TTL): saat kupon mulai diproses, statusnya dikunci sementara di Redis selama proses berlangsung, mencegah penggunaan paralel.	**High**	**Planned**

Input Sanitization & Integrity Check	Terapkan sanitasi input di semua entry point API: gunakan library validasi seperti Joi (Node.js) atau Bean Validation (Java) untuk memastikan tipe data, range nilai, dan format yang sesuai. Untuk mencegah manipulasi parameter di sisi klien, gunakan HMAC Signature pada request sensitif — server memverifikasi signature sebelum memproses request, sehingga parameter yang dimodifikasi penyerang akan ditolak karena signature tidak cocok. Implementasikan Content Security Policy (CSP) header untuk mencegah injeksi script berbahaya dari sisi browser.	Medium	Planned

Analisis : Ancaman Tampering memerlukan perubahan arsitektural pada lapisan backend yang harus diprioritaskan tinggi karena langsung berdampak pada integritas finansial transaksi. Server-Side Validation adalah fondasi mutlak — tanpa ini, semua mitigasi lain menjadi tidak efektif. Trade-off dari implementasi ini adalah sedikit peningkatan beban komputasi di server, namun jauh lebih aman dibandingkan mengandalkan validasi client-side yang mudah dimanipulasi.

6.2.3 Repudiation

Ancaman Repudiation berpusat pada fitur COD, di mana pengguna dapat menyangkal telah melakukan pemesanan atau menerima barang. Tiga vektor serangan yang diidentifikasi adalah: Use Fake Account (CAPEC-151), Use Shared Device (CAPEC-16), dan Exploit Weak Logging System (OWASP A09). Selain itu, terdapat ancaman Log Injection (CAPEC-93) pada fitur Login yang dapat memanipulasi audit trail.

Rekomendasi	Detail Implementasi	Prioritas	Status
OTP Konfirmasi Penerimaan COD	Implementasikan mekanisme verifikasi dua arah saat kurir melakukan serah terima barang COD: Sistem mengirimkan OTP unik ke nomor telepon terdaftar pembeli saat kurir tiba. Pembeli wajib memberikan kode OTP ini kepada kurir. Kurir memasukkan kode di aplikasi kurir sebelum dapat mengonfirmasi pengiriman selesai. Dengan ini, konfirmasi tidak lagi	High	Planned

	bersifat sepihak (hanya dari kurir), sehingga sistem memiliki bukti kuat bahwa pembeli secara aktif mengonfirmasi penerimaan barang. Secara teknis, OTP dihasilkan di backend, disimpan di Redis dengan TTL 15 menit, dan dikirimkan via SMS gateway yang sudah digunakan Shopee untuk OTP registrasi.		
Komprehensif Audit Logging & Immutable Log	Implementasikan sistem logging yang komprehensif dan anti-manipulasi menggunakan Apache Kafka (sudah tersedia di infrastruktur Shopee) sebagai log streaming pipeline. Setiap event kritis (login, logout, pemesanan, pembayaran, konfirmasi COD) harus mencatat: timestamp, user ID, IP address, device fingerprint, dan hash integritas data. Log disimpan di MongoDB dengan mekanisme write-once (append-only) sehingga tidak bisa dimodifikasi. Implementasikan WORM (Write Once Read Many) storage untuk log transaksi COD guna memenuhi persyaratan non-repudiation secara hukum. Gunakan static analysis tools secara berkala untuk mendeteksi kerentanan Log Injection (CAPEC-93).	**High**	**Planned**
Device Binding & Session	Implementasikan teknik pengikatan sesi ke perangkat menggunakan kombinasi: Device Fingerprint (browser/device attributes), IP address logging, dan User-Agent string. Sistem menyimpan informasi perangkat terdaftar per akun di Redis. Jika login terdeteksi dari perangkat yang tidak dikenal, sistem mengirimkan notifikasi keamanan ke pengguna dan memerlukan verifikasi tambahan. Tambahkan mekanisme Auto-Logout otomatis setelah periode tidak aktif (session timeout) dan Login Alert via push notification untuk aktivitas login baru. Khusus untuk transaksi COD dari perangkat publik atau shared, sistem dapat menambahkan langkah konfirmasi ekstra.	**Medium**	**Planned**

Analisis : Repudiation adalah ancaman yang paling langsung berdampak pada kerugian finansial bagi Shopee dan penjual melalui kasus penyangkalan COD. OTP konfirmasi

merupakan solusi paling efektif karena menciptakan bukti kriptografis yang tidak terbantahkan. Trade-off utama adalah tambahan satu langkah dalam proses serah terima yang mungkin sedikit memperlambat kurir, namun ini jauh lebih baik daripada kerugian finansial akibat penipuan COD yang sulit dibuktikan.

6.2.4 Information Disclosure

Ancaman Information Disclosure pada Shopee terutama berasal dari SQL Injection pada Search Bar (CAPEC-66) dan XSS (CAPEC-591) yang dapat mengekspos data sensitif pengguna, struktur database, hingga session token. Demonstrasi serangan pada OWASP Juice Shop juga membuktikan bahwa SQL Injection pada Login dapat menyebabkan kebocoran seluruh data pengguna termasuk admin credentials.

Rekomendasi	Detail Implementasi	Prioritas	Status
Parameterized Queries & ORM	Ganti seluruh dynamic SQL query (string concatenation) dengan Parameterized Queries / Prepared Statements di semua titik interaksi database. Untuk backend Java, gunakan Hibernate ORM atau Spring Data JPA. Untuk PHP, gunakan PDO dengan prepared statements. Parameterized queries memaksa database untuk memperlakukan input pengguna sebagai data literal, bukan perintah SQL yang dapat dieksekusi. Lakukan audit kode (code review) secara menyeluruh untuk mengidentifikasi dan mengganti semua instance penggunaan raw SQL query. Ini adalah mitigasi paling fundamental yang langsung menghilangkan akar penyebab (root cause) SQL Injection, sesuai temuan Root Cause Analysis pada Bagian 5.3.3.	**High**	**Planned**
Output Encoding & Web Application Firewall (WAF)	Untuk mencegah XSS (CAPEC-591): terapkan Output Encoding menggunakan library seperti OWASP Java Encoder atau DOMPurify (JavaScript) untuk mengubah karakter khusus HTML (<, >, ", ', &) menjadi HTML entities yang aman sebelum dirender di browser. Pasang Web Application Firewall (WAF) di level infrastruktur cloud (Cloudflare WAF sudah	**High**	**Planned**

	tersedia di Shopee) untuk menyaring dan memblokir payload SQL Injection dan XSS secara otomatis sebelum mencapai server aplikasi. Aktifkan rule set OWASP Core Rule Set (CRS) pada WAF sebagai baseline proteksi.		
Custom Error Pages & Principle Of Least Privilege	Konfigurasi server untuk mengembalikan generic error page yang tidak mengungkap informasi teknis sistem (seperti jenis database, stack trace, atau nama tabel) ke pengguna. Error detail hanya dicatat di server-side log yang aman, tidak dikirimkan ke response frontend. Terapkan Principle of Least Privilege pada akun database: akun yang digunakan aplikasi hanya diberikan hak akses minimum yang diperlukan (SELECT, INSERT, UPDATE pada tabel tertentu), bukan hak akses penuh seperti DROP TABLE atau akses ke tabel sistem. Ini membatasi dampak kerusakan jika SQL Injection berhasil.	**Medium**	**Planned**

Analisis : Parameterized Queries adalah remediasi wajib dan tidak opsional — ini merupakan standar industri yang harus segera diimplementasikan karena SQL Injection telah terbukti berhasil pada demonstrasi serangan (Bagian 5). WAF memberikan perlindungan ekstra di level jaringan. Custom error pages adalah mitigasi murah namun sering diabaikan yang efektif mencegah information gathering oleh penyerang.

6.2.5 Denial of Service

Ancaman DoS/DDoS pada Shopee teridentifikasi pada dua area: (1) HTTP Flooding pada Search Bar melalui query yang sangat panjang atau kompleks (CAPEC-469), dan (2) Request Spamming pada fitur promo oleh bot (CAPEC-125). Berdasarkan trade-off pada Excel Kelompok 3, Request Spamming pada promo dikategorikan sebagai Accept the Risk, sementara DoS pada Search Bar dikategorikan Address.

Rekomendasi	Detail Implementasi	Prioritas	Status
Rate Limiting & Query Timeout	Implementasikan Rate Limiting berlapis menggunakan Redis sebagai counter: Batasi maksimal 30 request	**High**	**Planned**

	pencarian per menit per pengguna terautentikasi dan 10 request per menit untuk pengguna anonim. Tambahkan batasan panjang karakter maksimal input search bar (misalnya 150 karakter) di sisi server — input yang melebihi batas langsung ditolak dengan HTTP 400 Bad Request tanpa diproses. Konfigurasi Query Timeout di database MySQL: query yang berjalan lebih dari 5 detik secara otomatis dihentikan. Implementasikan juga throttling di API Gateway level menggunakan middleware Express (Node) atau Spring Security (Java).		
Load Balancer & CDN Optimization	Manfaatkan infrastruktur cloud Shopee yang sudah ada (AWS/GCP/Alibaba Cloud) untuk mengonfigurasi Auto-Scaling pada cluster Kubernetes: saat traffic meningkat drastis (seperti saat promo), sistem otomatis menambah pod/instance baru untuk mendistribusikan beban. Aktifkan DDoS Protection bawaan Cloudflare (sudah digunakan Shopee sebagai CDN) dengan mode 'Under Attack' untuk serangan volumetrik. Implementasikan caching hasil pencarian populer menggunakan Redis dengan TTL pendek (60 detik) sehingga query berulang tidak membebani database secara langsung. Gunakan Cloudflare Rate Limiting Rules untuk memblokir IP yang mengirimkan traffic abnormal.	**High**	**Planned**
Accept Risk - Request Spamming Promo (Trade-Off)	Berdasarkan analisis trade-off Kelompok 3, risiko Request Spamming pada fitur promo diterima sebagai risiko bisnis (Accept the Risk). Justifikasi: biaya upgrade infrastruktur server untuk menangani lonjakan traffic bot promo skala besar dinilai tidak sebanding dengan nilai risiko finansial yang ditimbulkan, mengingat traffic promo tinggi adalah bagian dari siklus bisnis normal Shopee. Sebagai kompensasi risiko yang diterima, lakukan monitoring aktif menggunakan Prometheus & Grafana (sudah tersedia di Shopee) untuk mendeteksi anomali traffic secara real-time dan siapkan runbook respons insiden jika serangan melampaui kapasitas.	**Low**	**Accepted**

Analisis : Untuk DoS, strategi yang dipilih memanfaatkan infrastruktur yang sudah dimiliki Shopee (Cloudflare, Redis, Kubernetes) sehingga biaya tambahan minimal. Keputusan Accept Risk pada Request Spamming promo merupakan trade-off bisnis yang rasional — justifikasi utamanya adalah bahwa lonjakan traffic saat promo sebagian besar berasal dari pengguna nyata, sehingga terlalu agresif memblokir dapat juga memblokir pengguna legitimate.

6.2.6 Elevation of Privilege

Ancaman Elevation of Privilege terjadi ketika penyerang berhasil mendapatkan akses yang lebih tinggi dari yang seharusnya. Pada konteks Shopee, ini mencakup: SQL Injection pada Login yang memungkinkan akses sebagai Administrator (terbukti pada demonstrasi serangan Bagian 5), XSS yang mengakibatkan Session Hijacking ke akun Admin/Seller, dan manipulasi user state (CAPEC-74) setelah berhasil mengakses akun pengguna lain.

Rekomendasi	Detail Implementasi	Prioritas	Status
Role-Based Access Control (RBAC) & Principle Of Least Privilege	Implementasikan RBAC yang ketat: definisikan role yang jelas (Guest, Buyer, Seller, Admin, Super Admin) dengan permission matrix yang eksplisit di backend. Setiap API endpoint harus melakukan pemeriksaan otorisasi (authorization check) berdasarkan role pengguna yang terautentikasi — tidak cukup hanya mengecek apakah pengguna sudah login (authentication), tetapi juga harus memverifikasi apakah pengguna berhak mengakses resource tersebut (authorization). Gunakan framework seperti Spring Security (Java) atau middleware custom di PHP untuk mengelola RBAC. Admin Panel harus berada di subdomain terpisah dengan IP whitelist dan VPN requirement untuk akses.	**High**	**Planned**
Secure Session Management & HTTPOnly Cookie	Aktifkan flag HttpOnly dan Secure pada semua cookie session token sehingga token tidak dapat diakses oleh JavaScript di browser (mencegah theft via XSS). Gunakan flag SameSite=Strict untuk mencegah CSRF. Implementasikan session token rotation: setiap kali pengguna melakukan tindakan sensitif (checkout,	**High**	**Planned**

	ubah password, akses admin panel), session token diperbarui. Tambahkan Content Security Policy (CSP) header di semua response HTTP untuk mencegah eksekusi script asing yang dapat digunakan untuk mencuri session. Session token harus disimpan di Redis dengan TTL yang sesuai dan di-invalidasi saat logout.		
Server-Side State Management & Input Sanitization	Jangan menyimpan informasi privilege atau role pengguna di sisi klien (cookie, localStorage, atau URL parameter) — semua state otorisasi harus disimpan dan diverifikasi di sisi server menggunakan session ID yang di-map ke data server-side di Redis. Hindari menyimpan data sensitif seperti role, username, atau token autentikasi di lokasi yang dapat dimanipulasi pengguna. Terapkan Input Sanitization komprehensif (stripping HTML tags dan JavaScript) pada semua user-generated content (ulasan produk, komentar, deskripsi toko) menggunakan library seperti DOMPurify sebelum disimpan ke database dan sebelum dirender ke browser.	**Medium**	**Planned**

Analisis : Elevation of Privilege adalah ancaman dengan dampak paling katastrofik — terbukti dari demonstrasi serangan SQL Injection yang berhasil masuk sebagai Admin. RBAC yang ketat dan Secure Session Management adalah dua pilar utama yang harus diimplementasikan bersamaan. Server-Side State Management memastikan bahwa bahkan jika penyerang berhasil memodifikasi data di sisi klien, server tidak akan mempercayainya.

6.3 Roadmap Implementasi

Roadmap implementasi disusun berdasarkan prioritas ancaman dari hasil pemodelan STRIDE dan analisis trade-off Kelompok 3. Implementasi dibagi dalam tiga fase dengan mempertimbangkan urgency risiko, ketersediaan sumber daya teknis, dan ketergantungan antar komponen.

Fase	Periode	Kegiatan Mitigasi Utama	Komponen STRIDE
Fase 1 (Kritis)	0 - 3 Bulan (Jangka Pendek)	1. Implementasi Parameterized Queries / ORM di seluruh codebase (remediasi SQL Injection) 2. Aktifkan HttpOnly + Secure + SameSite cookie flags 3. Pasang Custom Error Pages (sembunyikan error teknis dari frontend) 4. Aktifkan Cloudflare WAF dengan OWASP Core Rule Set 5. Implementasi Rate Limiting & Account Lockout pada endpoint Login 6. Terapkan Server-Side Validation pada semua endpoint checkout & payment	Information Disclosure, Elevation of Privilege, Spoofing, Tampering
Fase 2 (Tinggi)	3 - 6 Bulan (Jangka Menengah)	1. Implementasi MFA (Push Notification / TOTP) untuk akun pengguna 2. Kembangkan dan deploy fitur OTP Konfirmasi Penerimaan COD 3. Implementasi Database Locking & Idempotency Key untuk transaksi 4. Terapkan RBAC yang ketat di backend (Spring Security / custom middleware) 5. Implementasi Comprehensive Audit Logging via Apache Kafka ke MongoDB (append-only) 6. Aktifkan Output Encoding (OWASP Encoder) pada semua user-generated content	Spoofing, Repudiation, Tampering, Elevation of Privilege, Information Disclosure

Fase 3 (Sedang)	6 - 12 Bulan (Jangka Panjang)	1. Implementasi KYC ringan (verifikasi nomor telepon wajib) & Device Fingerprinting 2. Kembangkan sistem Device Binding & Session Tracking komprehensif 3. Penguatan Admin Panel: IP whitelist, VPN requirement, audit log khusus admin 4. Program edukasi keamanan siber berkala untuk pengguna (transfer risk phishing promo) 5. Monitoring aktif dengan Prometheus & Grafana untuk anomali traffic DoS 6. Penetration Testing berkala dan Security Code Review rutin	Spoofing, Repudiation, Elevation of Privilege, Denial of Service (Transfer & Accept)

Catatan Prioritas: Fase 1 berfokus pada remediasi kerentanan kritis yang sudah terbukti dapat dieksploitasi (SQL Injection, seperti yang didemonstrasikan pada Bagian 5) dan mitigasi yang memanfaatkan infrastruktur yang sudah ada sehingga dapat diimplementasikan dengan cepat tanpa biaya tambahan yang signifikan. Fase 2 dan 3 memerlukan pengembangan fitur baru yang membutuhkan perencanaan kapasitas dan pengujian yang lebih matang.

7. Kesimpulan & Saran

7.1 Kesimpulan

Analisis arsitektur keamanan platform Shopee menggunakan kerangka kerja STRIDE berhasil memetakan ancaman kritikal di lima fitur fundamentalnya dengan temuan utama menunjukkan adanya risiko tinggi pada manipulasi logika bisnis kupon, aksi Repudiation pada sistem COD akibat absennya verifikasi dua arah serta risiko kelumpuhan infrastruktur (Denial of Service) akibat lonjakan request bot saat momentum promo. Dampak katastrofik ini terbukti melalui demonstrasi serangan Authentication Bypass via SQL Injection (SQLi) pada fitur login dimana penyerang mampu menembus perimeter tanpa kredensial sah sekaligus memicu Elevation of

Privilege otomatis menjadi akun Administrator dengan kontrol basis data penuh. Menghadapi ancaman tersebut, strategi mitigasi berbasis pendekatan Trade-Off yang diusulkan dinilai sangat efektif dan realistis untuk lanskap bisnis e-commerce; implementasi Parameterized Queries dan Server-Side Validation secara langsung memutus akar penyebab kerentanan teknis, sementara keputusan strategis untuk mengalihkan risiko (Transfer Risk) pada phishing lewat edukasi pengguna serta menerima risiko (Accept Risk) pada spam bot promo dengan kompensasi pemantauan aktif terbukti efisien dalam menjaga keseimbangan antara biaya operasional infrastruktur dan tingkat keamanan yang dapat diterima.

7.2 Saran

Berdasarkan hasil analisis, perusahaan disarankan untuk segera mengambil langkah actionable yang mencakup aspek teknis, proses, dan SDM demi memperkuat postur keamanan platform. Dari aspek teknis shopee wajib menutup celah SQL Injection dengan menerapkan Parameterized Queries di lapisan backend, memindahkan seluruh logika validasi diskon ke sisi server (Server-Side Validation), serta mengintegrasikan fitur kode verifikasi dua arah (OTP/QR Code) pada aplikasi kurir dan pembeli untuk mengeliminasi penipuan transaksi COD. Dari aspek proses, perusahaan perlu mengadopsi budaya DevSecOps dengan mengintegrasikan alat pemindai kode otomatis (SAST/DAST) ke dalam pipeline pengembangan perangkat lunak (SDLC), serta mengonfigurasi sistem audit log pada Apache Kafka agar bersifat append-only guna menjaga integritas data dari manipulasi. Terakhir dari aspek SDM shopee harus menyelenggarakan pelatihan Secure Coding secara berkala bagi tim pengembang untuk meminimalkan kelalaian penulisan kode, sekaligus meluncurkan kampanye edukasi siber yang agresif dan interaktif di dalam aplikasi guna meningkatkan kesadaran pengguna (buyer dan seller) terhadap ancaman rekayasa sosial seperti phishing promosi palsu.

8. Daftar Pustaka (References)

Sea Limited. (2026, Maret 3). *Sea Limited reports fourth quarter and full year 2025 results*. Sea Investor Relations. https://cdn.sea.com/investor/4Q2025/JcKns4LaJC8bxcQdJwXz/2026.03.03%20Sea%20Fourth%20Quarter%20and%20Full%20Year%202025%20Results.pdf

Sea Limited. (2025, Maret 4). *Sea Limited reports fourth quarter and full year 2024 results*. U.S. Securities and Exchange Commission (SEC). https://www.sec.gov/Archives/edgar/data/1703399/000119312525045576/d930776dex991.htm

Sea Limited. (2025). *Investor relations — About Sea*. Sea Group. https://www.sea.com/investor/home

Asosiasi Penyelenggara Jasa Internet Indonesia (APJII). (2025). *Survei penetrasi internet Indonesia 2025: E-commerce yang paling sering diakses*. Diakses melalui Selular.ID. https://selular.id/2025/08/shopee-dan-tiktok-shop-dominasi-pasar-e-commerce-indonesia-2025/

GoodStats. (2025, Agustus). *Daftar e-commerce paling sering diakses 2025, Shopee masih juara*. https://goodstats.id/article/e-commerce-paling-sering-diakses-2025-shopee-masih-juara-wyZqk

Bisnis.com. (2024, April 2). *5 platform e-commerce yang paling banyak dikunjungi, Shopee atau Tokopedia?* https://teknologi.bisnis.com/read/20240402/266/1754640/5-platform-e-commerce-yang-paling-banyak-dikunjungi-shopee-atau-tokopedia

Databoks / Katadata. (2025, Januari 30). *Shopee, e-commerce dengan penjualan produk kecantikan terbesar 2024*. https://databoks.katadata.co.id/teknologi-telekomunikasi/statistik/679b05d365d95/shopee-e-commerce-dengan-penjualan-produk-kecantikan-terbesar-2024

Semnesia. (2025, April 4). *35 data statistik e-commerce Indonesia yang penting*. https://semnesia.com/blog/data-statistik-ecommerce-indonesia/

ToffeeDev. (2025, Maret 14). *Shopee revenue model: Pelajari selengkapnya*. https://toffeedev.com/blog/e-commerce/shopee-revenue-model/

Midtrans. (2024). *5 model bisnis e-commerce yang ada di Indonesia*. https://midtrans.com/id/blog/5-model-bisnis-e-commerce-yang-ada-di-indonesia-sudah-tahukah-anda

SPayLater / PT Commerce Finance. (2025). *SPayLater — layanan buy now, pay later*. https://spaylater.co.id/

ShopeePay. (2024). *SPayLater adalah layanan beli sekarang bayar nanti*. https://shopeepay.co.id/blog/spaylater

Arjun. (2025, April 23). *Inside Shopee tech stack and infrastructure*. Appscrip Blog. https://appscrip.com/blog/inside-shopee-tech-stack-and-infrastructure/

Asosiasi Penyelenggara Jasa Internet Indonesia. (2025). *Laporan survei penetrasi dan perilaku pengguna internet Indonesia 2024–2025*. APJII.

Compas. (2024). *Indonesia e-commerce market share report 2024*. Compas Dashboard Analysis.

OWASP Top 10. (2021). *Top 10 web application security risks*. Open Web Application Security Project. https://owasp.org/www-project-top-ten/

Sea Limited. (2025). *Form 6-K: Current report for fourth quarter and full year 2024 results*. U.S.

Securities and Exchange Commission. https://www.sec.gov/edgar

Sea Limited. (2026). *Form 20-F: Annual report for the fiscal year ended December 31, 2025*. U.S. Securities and Exchange Commission. https://www.sec.gov/edgar

Shopee Engineering. (2024, 12 Oktober). Building scalable microservices architecture for high-traffic e-commerce. *Shopee Product & Engineering Blog*. https://engineering.shopee.io/

Shostack, A. (2014). *Threat modeling: Designing for security*. John Wiley & Sons.

SimilarWeb. (2025). *Market intelligence report: E-commerce and shopping performance in Indonesia 2025*. SimilarWeb Digital Insights.